TITAI v16

Reality-Gap Closure, Sovereign Runtime, and Operational Evidence Report

FINAL ENGINEERING AND ADVERSARIAL RELEASE REPORT

SOVEREIGN DEVELOPMENT MODE + DEVELOPMENT ONLY

TITAI v16 materially closes the gap between sovereign architecture and executable operational evidence. The release proves clean bounded tests, full production build, offline dependency installation from a verified cache, process-attributed network evidence, real migration rehearsal and rollback, portable purpose-separated key custody, governed lexical retrieval, and separate-process worker execution. It does not prove a real local generative model, unrestricted browser accessibility, operating-system or hardware-backed key custody, target mini-PC energy measurements, or two-physical-node operation.

Release	v16-operational-sovereignty
Input release	v15-sovereignty
Input SHA-256	db4f9063c57e03f3093cffc60c41c77bce3f73b45d1392fa774c72af2ae5e14a
Canonical state	100 tasks / 107 claims / 34 sources / 44 ADRs
Tests	64 files / 195 tests / zero timeouts
Build	31 pages / 2 workers / exit 0
Findings	84 total / 14 critical / 55 high / 15 medium
Report date	2026-07-11

This report is evidence-led. Missing proof remains blocking proof. No model, browser, hardware-key, energy, or independent-environment result is upgraded from unknown to pass.

1. Executive Decision

Release decision

The correct sovereignty classification is SOVEREIGN DEVELOPMENT MODE. The correct standard release classification is DEVELOPMENT ONLY. The system is substantially stronger than v15, but it does not satisfy the mandatory conditions for either a sovereign controlled pilot or a controlled internal pilot.

Why the release is not promoted

- No real local generative model was executed.
- Browser E2E, keyboard, screen-reader and visual regression remain blocked by managed browser policy.
- OS or hardware-backed key custody was not tested.
- Target mini-PC energy and thermal behavior was not measured.
- Offline dependency installation assumes a compatible preinstalled Node runtime.
- Two-physical-node synchronization was not proven.

What changed materially

- A vendor-neutral local runtime lifecycle with strict loopback and artifact-integrity boundaries.
- A real qualification lane that blocks when no signed model artifact or runtime endpoint exists.
- A portable encrypted keystore with purpose separation, rotation, retirement, revocation, expiry and scope binding.
- A governed BM25 lexical retrieval path that needs neither embeddings nor network access.
- A signed v15-to-v16 update rehearsal applying an actual SQLite migration and restoring prior schema and data.
- A clean-source npm dependency install from a verified offline cache with lifecycle scripts disabled.
- Process-attributed network evidence showing loopback-only attempts and no observed remote sockets in the selected proof workflow.
- A separately spawned signed worker identity with tenant/workspace scope and replay rejection.
- An authoritative per-file test runner proving process exit for all 64 files and 195 tests.
- A full production build with bounded workers and 31 generated pages.

2. Reproduced Starting State and Reality Gaps

Executive decision
TITAI v16 materially improves operational sovereignty, but it is not a controlled pilot. The correct classifications are `SOVEREIGN DEVELOPMENT MODE` and `DEVELOPMENT ONLY`.

Starting condition
v15 proved zero-key deterministic workflow execution, signed air-gap handoff, signed offline update and rollback, local memory portability, replay rejection, and a sovereignty control plane. It did not prove a real local generative model, a clean disconnected dependency install, process-level network evidence, migration rehearsal, a reliable all-tests exit, stronger key custody, real browser accessibility, or measured target-hardware energy.

Gap disposition

Reality gap	v16 status	Release effect
Real local generative model	Blocked: no signed artifact or runtime endpoint	Blocks sovereign pilot
Offline dependency installation	Passed with preinstalled Node and preverified cache	Partial operational proof
Process-level network evidence	Passed for selected Linux proof workflow	Substantial improvement
Purpose-separated key custody	Portable backend passed; OS/hardware backend blocked	Blocks higher-assurance custody
Browser and accessibility	Managed browser denied localhost	Blocks pilot
Multi-process / multi-node	Separate process passed; two physical nodes unproven	Partial
Energy and thermal measurement	CPU/RAM measured; energy counter unavailable	Blocks automated energy policy
External independent verifier	Final hash-bound verifier runs separately but same environment	Insufficient for pilot independence

3. Architecture Delta

TITAI v16 Architecture Delta

Purpose

v16 closes operational reality gaps without replacing the durable, tenant-scoped, local-first architecture introduced in earlier releases.

Added execution boundaries

Local model runtime boundary

The canonical runner can target a vendor-neutral lifecycle. Implementations include a loopback-only OpenAI-compatible adapter, a hash-verified llama.cpp subprocess adapter, a deterministic test runtime, and a fail-closed no-model runtime. No real generative artifact was available during this release, so model-quality evidence remains blocked.

Offline retrieval boundary

Canonical memory records remain authoritative. A local BM25 fallback applies tenant, workspace, sensitivity, expiry, status, contradiction, authority, confidence, and character-budget controls before ranking. The index is derived and reconstructable.

Key-custody boundary

A portable encrypted keystore separates installation, tenant, workspace, data, backup, handoff, update, and verifier purposes. It supports rotation, retirement, revocation, expiry, and scope enforcement. OS or hardware custody remains a separate blocked adapter.

Network-evidence boundary

Node connection APIs are instrumented and Linux process sockets are observed through `/proc`. Evidence associates attempts with PID, parent PID, executable, command, protocol, address, and port. This complements, rather than replaces, the application network policy.

Offline installation boundary

The source release remains dependency-free. A verified npm content-addressable cache can install the exact lockfile on a clean source copy in offline mode with lifecycle scripts disabled. Node remains a separately verified platform prerequisite.

Isolated execution identity

A controller process can issue a signed tenant/workspace capability lease to a separate worker process with a separate Ed25519 identity. Results are task-bound, integrity-checked, and replay-protected.

Test authority

Every test file executes in a new bounded Vitest process. Process exit is part of the pass condition. The monolithic suite remains diagnostic.

Preserved invariants

- Unknown evidence blocks pilot classification.
- No prompt, memory, or model response can grant authority.
- Remote model providers remain optional adapters.
- Model artifacts and runtime binaries are not packaged in the source release.
- Source archives exclude dependency trees, build output, databases, secrets, model weights, and generated native binaries.

4. Script, Skill, and Execution-Asset Audit

The repository was audited for existing scripts, skills, workflows, validators and release utilities before adding new mechanisms. The final registry distinguishes active release authority from diagnostic or review-only assets.

Measure	Count
Total assets	68
Scripts	54
Skills	12
CI workflows	2
Active assets	47
Release-gated assets	47
Review required	8

Representative registry entries

Asset	Kind	Offline	Release gate
scripts/audit-release.mjs	script	offline_capable	True
scripts/backup-application.mjs	script	offline_capable	True
scripts/benchmark-v12.ts	script	offline_capable	True
scripts/benchmark-v13.ts	script	offline_capable	True
scripts/build-context-pack.mjs	script	offline_capable	True
scripts/build-production.mjs	script	offline_capable	True
scripts/canonical-next.mjs	script	offline_capable	True
scripts/evaluate-baseline.ts	script	offline_capable	True
scripts/fixtures/v14-approval-process-worker.ts	script	offline_capable	False
scripts/fixtures/v14-db-lock-worker.ts	script	offline_capable	False
scripts/fixtures/v14-durable-process-worker.ts	script	offline_capable	False
scripts/fixtures/v14-outbox-process-worker.ts	script	offline_capable	False
scripts/generate-pilot-evidence-v14.mjs	script	offline_capable	True
scripts/generate-pilot-evidence.mjs	script	offline_capable	False
scripts/generate-release-evidence.mjs	script	offline_capable	True
scripts/generate-release-manifest.mjs	script	offline_capable	True
scripts/generate-v12-traceability.mjs	script	offline_capable	False
scripts/generate-v16-execution-registry.mjs	script	requires_review	True
scripts/generate-v16-pdf-report.py	script	offline_capable	False
scripts/lint-source.mjs	script	offline_capable	True
scripts/measure-v16-hardware.mjs	script	offline_capable	True
scripts/migrate.ts	script	offline_capable	True
scripts/mutation-v12.ts	script	offline_capable	True
scripts/mutation-v13.ts	script	offline_capable	True
scripts/network-audit-preload.cjs	script	requires_review	False

5. Local Runtime and Model Evidence

The runtime contract is operationally complete enough to start, load, health-check, tokenize, generate, stream, cancel, unload, emit metrics and shut down. Remote endpoints are not accepted by the local adapter, and artifact hashes are required. However, the qualification lane correctly returned blocked because no verified model artifact and no local generation endpoint were available.

Field	Evidence
Qualification status	blocked
Candidate only	Yes
Weights packaged	No
Quality claimed	No
Primary blockers	model_artifact_path_missing, local_runtime_endpoint_missing

Required next proof

- Execute a hash-verified local model on the target mini-PC.
- Measure structured-output validity, tool-call validity, unsafe-action rate, load time, time to first token, tokens per second, peak RAM/VRAM and energy.
- Bind benchmark revision and artifact hash into routing eligibility.

6. Sovereign Data, Retrieval, and Memory

The local governed store remains authoritative. v16 adds a network-free lexical/BM25 fallback that applies tenant, workspace, sensitivity, expiry, lifecycle and contradiction filters before relevance scoring. This provides a safe degraded path when local embeddings are unavailable.

Property	Result
Network required	No
Embedding model required	No
Scope filtering before ranking	Yes
Sensitivity and expiry filtering	Yes
Contradiction penalty	Yes
Context budget	Character bounded
Local embedding comparison	Not completed

7. Identity, Keys, and Cryptographic Custody

The portable keystore uses encrypted local storage and separates key purposes. Cross-purpose use is denied, and keys can be rotated, retired, revoked and expired. This is an important control improvement, but it is not equivalent to a non-exportable TPM, smart-card or operating-system key store.

Purpose	Implemented
Installation identity	Yes
Tenant encryption	Yes
Workspace encryption	Yes
Data encryption	Yes
Backup encryption	Yes
Handoff signing	Yes
Update signing	Yes
Verifier signing	Yes
OS or hardware backend	Blocked

8. Offline Installation and Update Rehearsal

Offline dependency installation

A clean source copy installed 334 lockfile-pinned packages from a preverified npm cache using offline mode and disabled lifecycle scripts. Type checking and sovereignty tests passed. This proves disconnected dependency installation under a compatible preinstalled Node runtime; it does not prove a bare-metal installer containing Node, operating-system packages or browser artifacts.

Measure	Result
Packages installed	334
Registry access during install	Disabled
Lifecycle scripts	Disabled
Type checking	Passed
Sovereignty tests	Passed
Prerequisite	Compatible Node runtime and prepared cache

Signed migration rehearsal

The signed update path applied the v16 migration to a real v15 SQLite schema, preserved sentinel data, validated the updated schema, then restored the previous source/schema/data state. The evidence distinguishes reverse migration from backup-based rollback.

9. Process Network Evidence

The selected sovereign workflow was executed under application instrumentation and Linux process/socket sampling. Four loopback attempts were recorded and zero remote sockets were observed. This is stronger than configuration-only offline claims, but it is not yet equivalent to a deny-all firewall capture on the user's target Windows machine.

Measure	Result
Instrumented attempts	[{'at': '2026-07-11T13:18:19.519Z', 'pid': 11392, 'ppid': 11381, 'executable': '/opt/nvm/versions/node/v22.16.0/bin/node', 'argv': ['/opt/nvm/versions/node/v22.16.0/bin/node', '/mnt/data/titai_v16_work/scripts/prove-v15-sovereignty.ts'], 'kind': 'tcp_connect', 'host': 'localhost'}, {'at': '2026-07-11T13:18:19.627Z', 'pid': 11392, 'ppid': 11381, 'executable': '/opt/nvm/versions/node/v22.16.0/bin/node', 'argv': ['/opt/nvm/versions/node/v22.16.0/bin/node', '/mnt/data/titai_v16_work/scripts/prove-v15-sovereignty.ts'], 'kind': 'tcp_connect', 'host': 'localhost'}, {'at': '2026-07-11T13:18:19.762Z', 'pid': 11392, 'ppid': 11381, 'executable': '/opt/nvm/versions/node/v22.16.0/bin/node', 'argv': ['/opt/nvm/versions/node/v22.16.0/bin/node'], 'kind': 'tcp_connect', 'host': 'localhost'}, {'at': '2026-07-11T13:18:19.850Z', 'pid': 11392, 'ppid': 11381, 'executable': '/opt/nvm/versions/node/v22.16.0/bin/node', 'argv': ['/opt/nvm/versions/node/v22.16.0/bin/node'], 'kind': 'tcp_connect', 'host': 'localhost'}]
Observed remote sockets	0
Allowed destination class	Loopback
Unexpected remote traffic	None observed
Target Windows attribution	Not tested

10. Multi-Process and Node Trust

A separately spawned worker process with a separate signing identity received a tenant/workspace-scoped signed lease, returned a result bound to the exact task and scope, and had replay rejected. This proves process separation and signed work transfer on one physical host. It does not prove synchronization, failover or conflict resolution across two physical machines.

Property	Result
Separate controller and worker PID	Passed
Separate signing identity	Passed
Tenant/workspace scope	Passed
Result replay rejection	Passed
Network dependency	None
Two physical machines	Not proven

11. Browser, Accessibility, and Product Reality

The production application was started with a disposable seeded database and temporary password. Chromium was invoked against localhost, but the managed system policy denied navigation with ERR_BLOCKED_BY_ADMINISTRATOR. The policy was not modified or bypassed. Therefore browser E2E, keyboard, focus, screen-reader, responsive, offline and visual-regression evidence remains blocked.

Operator-control surfaces implemented in source

- Sovereignty topology and evidence gates.
- Model locality and qualification state.
- Network-evidence status.
- Key-custody status.
- Offline-install and update readiness.
- Node identity and worker evidence.
- Unknown evidence displayed as blocking evidence.

12. Test, Build, and Adversarial Evidence

Gate	Result
Canonical validation	100 tasks / 107 claims / 34 sources / 44 ADRs
Migrations	10 files / 18 required tables
Authoritative isolated tests	64 files / 195 tests / 0 timeout
Baseline evaluation	8 / 8
Durable crash proof	2 attempts / exactly 1 side effect
Static Roast	43 / 44
Dynamic Roast	6 / 6
v13 mutation probes	12 / 12 killed
v12 mutation probes	6 / 6 killed
Production build	Passed / 69 sec / 31 pages / 2 workers
Build peak RSS	1323 MB

13. Breakthrough and Opportunity Portfolio

The v16 hypothesis portfolio selected runtime-neutral local inference, purpose-separated portable key custody, and network-free governed retrieval as the three decisive slices.

Thirty-candidate sovereign opportunity portfolio

ID	Opportunity	Priority / status
V16-OPP-01		3.0
V16-OPP-02		2.33
V16-OPP-03		8.0
V16-OPP-04		4.5
V16-OPP-05		1.67
V16-OPP-06		6.0
V16-OPP-07		3.5
V16-OPP-08		2.67
V16-OPP-09		9.0
V16-OPP-10		2.5
V16-OPP-11		2.0
V16-OPP-12		7.0
V16-OPP-13		4.0
V16-OPP-14		3.0
V16-OPP-15		5.0
V16-OPP-16		3.0
V16-OPP-17		2.33
V16-OPP-18		8.0
V16-OPP-19		4.5
V16-OPP-20		1.67
V16-OPP-21		6.0
V16-OPP-22		3.5
V16-OPP-23		2.67
V16-OPP-24		9.0
V16-OPP-25		2.5
V16-OPP-26		2.0
V16-OPP-27		7.0
V16-OPP-28		4.0
V16-OPP-29		3.0
V16-OPP-30		5.0

14. Full Roast Register

The final Roast register contains 84 historical and current findings. Historical findings remain present even when fixed, so the release does not erase earlier risk evidence.

Status	Count
accepted_risk	1
environment_blocked	5
fixed_in_v10	6
fixed_in_v11	3
fixed_in_v12	5
fixed_in_v13	2
fixed_in_v14	4
fixed_in_v15	1
fixed_in_v16	3
fixed_in_v8	13
open	7
partially_mitigated	34

Severity	Count
critical	14
high	55
medium	15

F-001 - Detached in-memory execution cannot survive process loss

Severity: critical | Status: partially_mitigated | Category: durability | Confidence: high

Finding: A feature-flagged durable envelope and SQLite durable primitives now exist, but granular step resume and active restart recovery remain incomplete.

Impact: Long-running or side-effecting jobs can disappear, duplicate, or remain permanently inconsistent after deployment, crash, or upgrade.

Recommendation: Complete native multi-process crash tests and replace the single-step envelope with granular checkpoints and fencing.

Acceptance: Kill the worker at every checkpoint boundary and prove the run resumes exactly once with preserved ownership and evidence.

F-002 - Side effects lack persisted idempotency and atomic evidence

Severity: critical | Status: partially_mitigated | Category: durability | Confidence: high

Finding: The v9 portable core now persists deterministic side-effect receipts and proves crash replay without duplication. The production runner still lacks the SQLite transactional receipt, event, and audit integration.

Impact: A crash after a side effect but before acknowledgement can repeat irreversible work or create evidence that disagrees with reality.

Recommendation: Migrate the production runner to the portable contract with a SQLite compare-and-set lease and transactional outbox.

Acceptance: Inject a crash after external success but before event commit and prove the retry does not repeat the effect.

F-003 - Deployment model conflicts with globally shared mutable data

Severity: critical | Status: partially_mitigated | Category: identity-tenancy | Confidence: high

Finding: Authentication is multi-user, but policies, templates, and parts of audit/configuration are global rather than tenant-owned. Administrative restrictions reduce some exposure but do not establish a complete tenancy model.

Impact: One user can be affected by another user's global configuration or data; future multi-user deployment risks cross-tenant leakage and confused authority.

Recommendation: Choose and enforce either explicit single-owner mode or workspace/tenant ownership across every mutable record and query.

Acceptance: Create two tenants and prove every read, write, audit, template, skill, run, and artifact is isolated under adversarial identifiers.

F-004 - HTTP and provider endpoints allowed server-side request forgery

Severity: critical | Status: fixed_in_v8 | Category: security-egress | Confidence: high

Finding: User-influenced HTTP and provider base URLs previously had no private-network, loopback, metadata, DNS-rebinding, or redirect boundary.

Impact: An agent could probe internal services, cloud metadata, or local control planes.

Recommendation: Keep destination and redirect validation, DNS resolution checks, and explicit local-model exceptions under policy.

Acceptance: Run the egress suite against loopback, RFC1918, link-local, metadata, IPv6, encoded addresses, mixed DNS answers, and redirect chains.

F-005 - Invalid or cyclic plans could be reported as completed

Severity: critical | Status: fixed_in_v8 | Category: runtime-correctness | Confidence: high

Finding: The original scheduler could reach no-ready-step state while unfinished nodes remained and still finish the run successfully.

Impact: A structurally impossible plan could produce a false success signal and misleading evidence.

Recommendation: Retain preflight plan validation and fail closed when unfinished work has no executable node.

Acceptance: Test duplicate nodes, unknown edges, self-dependencies, cycles, excessive steps, and runtime deadlock.

F-006 - No tested sovereign backup and restore path

Severity: critical | Status: fixed_in_v10 | Category: recovery | Confidence: high

Finding: The v10 package creates a consistent SQLite snapshot, encrypts it with scrypt and AES-256-GCM, verifies integrity and required tables, restores atomically, preserves an overwritten database, and includes positive and negative restore tests.

Impact: Loss or corruption of the SQLite database, keys, artifacts, or model configuration can be unrecoverable.

Recommendation: Run periodic clean-deployment RTO/RPO drills and store the passphrase separately from the backup.

Acceptance: Restore the encrypted backup into a clean target, verify the sentinel data and database checks, then prove wrong-key, tamper, and unauthorized-overwrite attempts fail closed.

F-007 - Drizzle ORM remains on a version with a high-severity advisory

Severity: high | Status: open | Category: supply-chain | Confidence: high

Finding: The current dependency range resolves below the audited fixed line identified by npm audit for identifier-related SQL injection.

Impact: Unsafe identifier construction in affected paths can turn application input into SQL structure rather than data.

Recommendation: Upgrade Drizzle ORM to a supported non-vulnerable release, regenerate/migrate safely, and execute database integration tests.

Acceptance: npm audit contains no high advisory for Drizzle and all migration/query/integration tests pass on a clean install.

F-008 - Any authenticated user could mutate global policy

Severity: high | Status: fixed_in_v8 | Category: authorization | Confidence: high

Finding: The policy update path previously had an ineffective administrative check while changing system-wide policy.

Impact: A normal user could weaken approval requirements for all users.

Recommendation: Retain explicit administrative authorization and later tenant-scope policy records.

Acceptance: A non-admin receives a denial and cannot change persisted policy; an authorized admin creates an attributable audit event.

F-009 - Skill identifiers enabled cross-user prompt access or attachment

Severity: high | Status: fixed_in_v8 | Category: authorization | Confidence: high

Finding: Direct skill fetch and agent skill replacement did not consistently verify ownership.

Impact: A user who guessed an identifier could read or attach another user's procedural prompt material.

Recommendation: Keep owner/built-in checks on both reads and relationship writes.

Acceptance: Attempt direct reads and attachment with another user's skill identifier and prove denial without existence leakage.

F-010 - New or empty agents inherited every tool

Severity: high | Status: fixed_in_v8 | Category: capability-security | Confidence: high

Finding: Agent creation and runtime fallback could translate absent or empty tool configuration into the full registry.

Impact: A minimally configured agent could unexpectedly gain network or write authority.

Recommendation: Keep an explicit low-risk default allowlist and treat an empty list as no capabilities.

Acceptance: Create agents with omitted and empty tool lists; prove only documented tools can execute.

F-011 - Catch-all policy allowed medium-risk actions automatically

Severity: high | Status: fixed_in_v8 | Category: human-oversight | Confidence: high

Finding: The default policy set included a broad catch-all automatic path that weakened the documented fallback behavior.

Impact: Risky actions could bypass human review despite the UI implying otherwise.

Recommendation: Keep fail-closed fallback policy and require explicit, narrow auto-approval rules.

Acceptance: Unknown and medium/high-risk actions resolve to human review or denial in policy tests.

F-012 - Runs and approvals have no complete wall-clock deadline model

Severity: high | Status: partially_mitigated | Category: reliability | Confidence: high

Finding: Runs now accept explicit wall-clock deadlines and output/context budgets; approvals persist an expiry timestamp and are expired by local timers and boot recovery. A durable timer service and restart-safe continuation are still absent.

Impact: A run can occupy resources indefinitely or remain pending forever after user abandonment.

Recommendation: Add persisted deadlines, timeout ownership, cancellation propagation, and deterministic terminal states.

Acceptance: Advance a fake clock across model, tool, approval, and run deadlines and prove exact terminal events and released leases.

F-013 - Run event sequence allocation is race-prone

Severity: high | Status: partially_mitigated | Category: integrity | Confidence: high

Finding: Run event sequence allocation and insertion now execute under BEGIN IMMEDIATE with a unique run/sequence constraint and an atomic outbox record. Native multi-process contention tests remain blocked in this environment.

Impact: Concurrent writers can duplicate or reorder sequence numbers and break replay evidence.

Recommendation: Use a transactionally allocated sequence or append-only event table with a unique run/sequence constraint and retry.

Acceptance: Run concurrent appenders and prove contiguous unique ordering under load and injected transaction retries.

F-014 - Audit hash-chain append is race-prone and not externally anchored

Severity: high | Status: partially_mitigated | Category: audit-integrity | Confidence: high

Finding: Audit hash-chain read, hash calculation, append, and outbox insertion now run in one immediate transaction. External anchoring and native concurrent-writer tests remain.

Impact: Concurrent events can fork the chain; a database administrator can rewrite the entire chain and recompute hashes.

Recommendation: Serialize append, add uniqueness, sign periodic roots, and optionally export roots to independent storage.

Acceptance: Generate concurrent audit writes, verify one linear chain, then mutate history and prove signed-root verification fails.

F-015 - Disabled provider configurations were still eligible

Severity: high | Status: fixed_in_v8 | Category: provider-routing | Confidence: high

Finding: Provider activation status was not consistently enforced during dispatch or provider tests.

Impact: An operator could believe a provider was disabled while the system still sent data to it.

Recommendation: Retain enabled checks at every provider resolution boundary.

Acceptance: Disable each provider and prove dispatch, health test, and fallback routing never contact it.

F-016 - Database migration failure was tolerated

Severity: high | Status: fixed_in_v8 | Category: startup-integrity | Confidence: high

Finding: Migration errors were logged but startup could continue against an unknown schema.

Impact: The application could write incompatible data or fail later in less diagnosable ways.

Recommendation: Keep startup fail-closed for required schema migrations.

Acceptance: Force a migration failure and prove the process refuses readiness without serving mutation routes.

F-017 - Fetched content remains a prompt-injection channel

Severity: high | Status: partially_mitigated | Category: agent-security | Confidence: high

Finding: Fetched data is now labeled untrusted and egress-limited, but untrusted text still enters model context without a fully enforced authority separation or content transformation policy.

Impact: A malicious page can attempt to override instructions, induce tool use, or exfiltrate context.

Recommendation: Separate data from instructions, apply trust labels in the internal protocol, and require policy authorization independent of model text.

Acceptance: Use adversarial fetched pages that request secrets and destructive tools; prove zero authority escalation and no protected-context leakage.

F-018 - Native database integration tests cannot run in the constrained environment

Severity: high | Status: environment_blocked | Category: verification | Confidence: high

Finding: The safe install deliberately skips native post-install scripts, leaving better-sqlite3 unavailable for three database-backed suites.

Impact: Critical approval expiry, audit, and runner integration behavior is not independently executed in this environment.

Recommendation: Run the blocked suites on an approved clean Linux CI image with pinned Node headers and a trusted prebuilt/native toolchain.

Acceptance: All database suites pass from a clean lockfile install and publish logs, environment digest, and database reset evidence.

F-019 - Production build did not complete end-to-end in the audit environment

Severity: high | Status: environment_blocked | Category: release-verification | Confidence: high

Finding: The production build compiles and completes type validation, but page-data collection cannot load the absent better-sqlite3 native binding in the constrained environment.

Impact: A source-level and compile-level green result does not prove deployable application startup or route data collection.

Recommendation: Run the build with the verified native binding on a trusted CI or development host, then execute startup and browser E2E gates.

Acceptance: A clean install completes the production build, starts the server, and passes Playwright without hidden network or native-binding errors.

F-020 - User data export, correction, and deletion are not implemented end-to-end

Severity: high | Status: partially_mitigated | Category: data-governance | Confidence: high

Finding: User export, password-confirmed deletion, owned-data cascade, governed-memory correction/deletion, and logical audit redaction overlays are implemented. Native end-to-end deletion, backup propagation, and legal retention validation remain.

Impact: Users cannot exercise data rights reliably and deleted data may survive in logs, artifacts, or backups.

Recommendation: Implement data inventory-backed export and deletion workflows with tombstone/backup semantics and audit evidence.

Acceptance: Create a user with all data classes, export it, delete it, search every primary/derived store, restore an older backup, and prove policy-compliant handling.

F-021 - Custom templates are globally visible and mutable

Severity: high | Status: fixed_in_v10 | Category: identity-tenancy | Confidence: high

Finding: Custom templates now carry an owner identifier; listing and creation expose only built-in templates plus the authenticated user's templates.

Impact: Private workflows or proprietary prompts can be exposed or changed across users.

Recommendation: Separate immutable built-ins from tenant-owned custom templates and scope every query.

Acceptance: Two-user route tests prove private templates cannot be listed, read, updated, or referenced cross-tenant.

F-022 - Audit access is restricted but audit data remains globally modeled

Severity: high | Status: partially_mitigated | Category: identity-tenancy | Confidence: high

Finding: The route now restricts entries to administrators, but audit rows lack a complete tenant/workspace ownership model and delegated audit roles.

Impact: A global administrator becomes a high-value data aggregation point and tenant-level audit cannot be safely delegated.

Recommendation: Add tenant/workspace dimensions and explicit audit-reader roles while preserving system-level security audit separation.

Acceptance: Tenant auditors see only their workspace; system auditors see redacted cross-tenant metadata under separate authorization.

F-023 - Registration remains open with weak abuse controls

Severity: high | Status: fixed_in_v10 | Category: authentication | Confidence: high

Finding: Registration now bootstraps only the first administrator by default, remains closed afterward unless explicitly enabled, supports an invite token, enforces a twelve-character minimum, and uses rate limiting without trusting proxy headers by default.

Impact: An exposed installation can be populated by unauthorized users and amplified against local or paid model resources.

Recommendation: Add explicit registration mode, invitation/first-owner bootstrap, stronger password checks, throttling, and non-enumerating responses.

Acceptance: Unauthenticated registration is denied in closed mode; invite reuse, enumeration, weak passwords, and burst attempts fail safely.

F-024 - Secret encryption lacks documented rotation and context binding

Severity: high | Status: partially_mitigated | Category: cryptography | Confidence: medium

Finding: Provider secrets now use versioned AES-GCM records, HKDF purpose separation, and user/provider context binding with legacy decryption compatibility. Automated rotation, revocation, and custody recovery are not complete.

Impact: A leaked master key or ciphertext relocation can expose all provider credentials with limited recovery options.

Recommendation: Introduce key IDs, rotation, AEAD associated data, scoped decrypt authority, secure backup handling, and revocation drills.

Acceptance: Rotate from key A to B without downtime, prove old ciphertext migration, reject swapped record context, and restore credentials securely.

F-025 - Run creation has no client idempotency contract

Severity: high | Status: partially_mitigated | Category: api-reliability | Confidence: high

Finding: Run creation accepts a user-scoped Idempotency-Key, serializes create-or-reuse under BEGIN IMMEDIATE, rejects key reuse with a different request, and has a unique database constraint. Native concurrent API tests remain blocked.

Impact: Network retries or double clicks can duplicate expensive or destructive work.

Recommendation: Accept scoped idempotency keys, persist request/result hashes, and return the original run for safe retries.

Acceptance: Send the same request concurrently and repeatedly; prove exactly one run and a deterministic replay response.

F-026 - Approval expiry is not owned by a durable timer

Severity: high | Status: partially_mitigated | Category: human-oversight | Confidence: high

Finding: Approval expiry is persisted and enforced by local wait timers and startup sweeping, but no independent durable timer worker owns expiry while the application is offline.

Impact: Expired approvals can remain pending or resume ambiguously, blocking work and weakening policy guarantees.

Recommendation: Persist approval deadlines and let a durable worker own expiry, cancellation, and notification.

Acceptance: Restart before and after expiry and prove one deterministic expired transition and no later execution.

F-027 - Restart semantics for pending approvals are incomplete

Severity: high | Status: partially_mitigated | Category: recovery | Confidence: high

Finding: A serializable revision-checked approval wait contract now proves one-decision and expiry semantics, but the active runner still cannot resume it after restart.

Impact: An approved action may never resume or may be reissued incorrectly after restart.

Recommendation: Persist the wait contract, durable timer, continuation pointer, and requeue behavior in the active runner.

Acceptance: Restart with a pending approval, decide it from another process, and prove the exact continuation resumes once.

F-028 - Configured maximum plan size was not enforced

Severity: high | Status: fixed_in_v8 | Category: resource-governance | Confidence: high

Finding: The planner schema previously accepted plans beyond the configured step limit.

Impact: A model could create runaway work graphs and consume disproportionate resources.

Recommendation: Keep max-step enforcement at parse/validation time.

Acceptance: Generate plans at limit, limit+1, and extreme sizes; prove bounded parse time and clear rejection.

F-029 - Tool iteration exhaustion could be treated as success

Severity: high | Status: fixed_in_v8 | Category: runtime-correctness | Confidence: high

Finding: A step could leave the model still requesting tools after the loop budget but continue toward completion.

Impact: Incomplete or looping work could be presented as successful.

Recommendation: Fail the step and run with explicit budget-exhausted evidence.

Acceptance: Use a model fixture that always requests another tool and prove deterministic failure at the configured limit.

F-030 - Usage accounting could double-count tokens

Severity: medium | Status: fixed_in_v8 | Category: economics | Confidence: high

Finding: Token usage could be recorded both through provider events and response usage aggregation.

Impact: Cost, capacity, and model-routing decisions could be based on inflated telemetry.

Recommendation: Use one authoritative accounting path with reconciliation fields.

Acceptance: Replay a response with provider usage events and summary usage; prove totals equal the provider bill once.

F-031 - Rejected approval did not close the tool evidence chain

Severity: medium | Status: fixed_in_v8 | Category: evidence-integrity | Confidence: high

Finding: A rejected action produced a model-facing result but no matching tool.result event.

Impact: Evidence reconstruction reported an unmatched call and could not explain the human decision path.

Recommendation: Emit a terminal tool result representing rejection without executing the tool.

Acceptance: Reject an approval and prove call/result pairing, no side effect, and visible human-decision evidence.

F-032 - Prompts and objectives are duplicated into persistent evidence without minimization

Severity: medium | Status: partially_mitigated | Category: privacy | Confidence: high

Finding: Full system prompts and run objectives are no longer duplicated into run-start events or audit payloads; hashes and character counts are stored instead. The objective remains once in the run record because it is operational input, and broader retention controls remain.

Impact: Sensitive business data can persist longer and in more stores than users expect.

Recommendation: Store references/hashes and redacted summaries by default; define an explicit secure evidence retention mode for full content.

Acceptance: Insert known sensitive markers and prove default logs/events/audit omit them while authorized artifact storage remains traceable.

F-033 - Artifact writes had no practical size ceiling

Severity: medium | Status: fixed_in_v8 | Category: resource-governance | Confidence: high

Finding: The write-artifact tool accepted unbounded content.

Impact: A model could exhaust memory, disk, database capacity, or UI rendering.

Recommendation: Keep a documented byte cap and later add streaming/object storage where justified.

Acceptance: Attempt boundary, boundary+1, and multibyte payloads and prove exact size enforcement.

F-034 - Policy regular expressions can create denial of service

Severity: medium | Status: fixed_in_v10 | Category: policy-engine | Confidence: medium

Finding: Policy patterns pass a bounded safe-regex compiler that rejects oversized expressions, backreferences, lookarounds, nested quantifiers, repeated wildcards, and malformed patterns before evaluation.

Impact: Catastrophic backtracking can block the Node.js event loop during authorization.

Recommendation: Use constrained glob/pattern semantics or safe-regex validation and bounded evaluation.

Acceptance: Submit known pathological expressions and long inputs; prove bounded latency or rejection.

F-035 - Rate limiting is process-local and trusts client forwarding headers

Severity: medium | Status: partially_mitigated | Category: abuse-control | Confidence: high

Finding: Forwarding headers are ignored unless proxy trust is explicitly enabled. Rate-limit state remains process-local and therefore is not a distributed production control.

Impact: Attackers can bypass limits across workers/restarts or by rotating forged header values.

Recommendation: Use authenticated principal/workspace keys and a shared limiter or documented single-process boundary; configure trusted proxies explicitly.

Acceptance: Exercise multiple workers, restarts, spoofed headers, users, and IPs; prove the intended global and per-user budget.

F-036 - Security headers improved but CSP remains absent

Severity: medium | Status: partially_mitigated | Category: browser-security | Confidence: high

Finding: The application now sends a Content Security Policy and baseline headers. The compatibility policy still permits inline scripts and styles, and browser-level enforcement tests remain.

Impact: A future injection bug has fewer browser-side containment barriers.

Recommendation: Add nonce/hash-based CSP, report-only rollout, and route tests without breaking Next.js runtime behavior.

Acceptance: Production responses include the approved CSP and Playwright confirms no required script/style violations.

F-037 - Source lint is intentionally shallow and build ignores ESLint

Severity: medium | Status: partially_mitigated | Category: code-quality | Confidence: high

Finding: Build no longer suppresses ESLint and the non-interactive source lint checks merge markers, dangerous directives, dynamic code execution, malformed JSON, and client/server boundaries. A full semantic ESLint ruleset remains absent.

Impact: Common correctness, React, security, and accessibility defects can pass CI.

Recommendation: Adopt a pinned non-interactive ESLint configuration plus targeted security/accessibility rules and keep the fast scanner as an additional gate.

Acceptance: A clean install runs lint non-interactively; seeded violations fail with stable diagnostics.

F-038 - No generated SBOM, model inventory, or build provenance

Severity: high | Status: fixed_in_v10 | Category: supply-chain | Confidence: high

Finding: The release pipeline generates a CycloneDX SBOM, license inventory, model inventory, and source-tree build provenance with hashes.

Impact: Operators cannot reliably identify vulnerable components, licenses, models, plugins, or reproduce the artifact.

Recommendation: Generate CycloneDX/SPDX, license inventory, model/plugin hashes, and build provenance during release.

Acceptance: The extracted ZIP contains validated inventories matching the lockfile and shipped artifacts, signed or hashed in the release manifest.

F-039 - Observability lacks traces, SLOs, and capacity evidence

Severity: high | Status: partially_mitigated | Category: observability | Confidence: high

Finding: A local metrics endpoint now reports status counts, latency percentiles, token usage, approval expiry, outbox backlog, durable-job state, and SLO evaluations. Cross-boundary traces, energy measurement, historical capacity series, and telemetry retention remain.

Impact: Operators cannot answer why work is slow, expensive, failing, or saturating resources.

Recommendation: Add redacted trace correlation, metrics, usage reconciliation, queue measures, SLOs, and local dashboards.

Acceptance: A benchmark run yields traceable p50/p95/p99 latency, queue depth, failure classes, token/cost totals, and an SLO verdict.

F-040 - Governed memory architecture is documentation-only

Severity: high | Status: fixed_in_v11 | Category: memory | Confidence: high

Finding: Governed memory is implemented and integrated into prompt assembly with owner filtering, expiry, token budgets, quarantine, provenance labeling, corrections, and deletion.

Impact: Long-running agents either forget important context or accumulate untrusted, stale, contradictory, or cross-user material.

Recommendation: Maintain ablation and poisoning evaluations before expanding automatic memory creation.

Acceptance: Create contradictory, expired, private, corrected, and deleted memories; prove scoring, provenance, isolation, and removal behavior.

F-041 - Provider selection is not a measured capability router

Severity: high | Status: fixed_in_v11 | Category: model-routing | Confidence: high

Finding: Model capability profiles, hard eligibility constraints, deterministic utility scoring, explicit fallback, no-eligible failure, persistence, API control, and run-level rationale are implemented.

Impact: Critical work can be dispatched by static configuration rather than demonstrated fitness.

Recommendation: Populate profiles through repeatable benchmark runs and invalidate stale evaluations.

Acceptance: Given constrained tasks and unavailable models, route to the Pareto-eligible candidate or return no-eligible-model without silent downgrade.

F-042 - Test portfolio is too narrow for the threat and failure model

Severity: high | Status: partially_mitigated | Category: evaluation | Confidence: high

Finding: The safe portfolio now includes lifecycle, evidence, egress, durable execution, backup/restore, memory, regex, tool-schema, metrics, context-budget, graph, crypto, and policy tests. Native database, browser, accessibility, load, and broad fault-injection suites remain incomplete.

Impact: The system can pass 47 safe tests while remaining unsafe under realistic operation.

Recommendation: Build layered adversarial and fault-injection suites tied to every high/critical finding.

Acceptance: Each high/critical finding has a failing regression before repair and a passing independent verification after repair.

F-043 - End-to-end tests are brittle smoke checks

Severity: medium | Status: partially_mitigated | Category: evaluation | Confidence: high

Finding: The Playwright suite now uses operator-supplied credentials, semantic readiness conditions, and coverage for run evidence, agent evaluation, and governed-memory lifecycle. Isolated database fixtures, repeated parallel/serial execution, accessibility assertions, and measured flake-rate evidence remain.

Impact: The suite is materially less brittle, but shared-state and unexecuted browser coverage can still conceal authorization, recovery, accessibility, or concurrency regressions.

Recommendation: Add per-run isolated databases and users, deterministic fixture teardown, accessibility checks, authorization negatives, restart recovery, and repeated serial/parallel flake measurement.

Acceptance: Run the E2E suite repeatedly in serial and parallel modes against isolated state, including accessibility, authorization, offline, and recovery cases, with a bounded measured flake rate.

F-044 - Seed workflow is destructive and includes known demo credentials

Severity: medium | Status: fixed_in_v10 | Category: operations | Confidence: high

Finding: The seed refuses to run unless a destructive-seed flag is set, requires an operator-supplied twelve-character demo password, and no longer contains fallback application secrets or prints credentials.

Impact: Running it in the wrong environment can destroy data or create an easily guessed account.

Recommendation: Require explicit development/test environment, random ephemeral credentials, targeted fixture cleanup, and destructive confirmation guards.

Acceptance: Attempt seed in production mode and against a non-empty protected database; prove hard refusal and no mutation.

F-045 - Evidence percentage measures structure, not truth

Severity: medium | Status: partially_mitigated | Category: evidence-quality | Confidence: high

Finding: The UI originally risked presenting event-shape completeness as overall evidence quality. It is now labeled structural coverage, but semantic correctness and verifier independence remain separate unfinished controls.

Impact: Users can over-trust a complete-looking ledger even when outputs are wrong or self-verified.

Recommendation: Keep structural labeling and add claim-level evidence, verifier identity, reproducibility, contradiction, and semantic evaluation.

Acceptance: Show a structurally complete but deliberately false run and prove the UI does not label it verified.

F-046 - Most canonical capabilities remain blocked or unimplemented

Severity: high | Status: partially_mitigated | Category: program-execution | Confidence: high

Finding: v9 and v10 implement durable contracts, SQLite persistence primitives, transactional outbox, governed memory, encrypted restore, lifecycle controls, observability, data export/deletion, budgets, and release provenance. Production worker cutover, measured routing, delegated identity, and full native/browser verification remain.

Impact: Documentation volume can be mistaken for platform maturity, obscuring the implementation gap.

Recommendation: Expose implemented-versus-designed status prominently and execute dependency-unblocking vertical slices rather than adding parallel documents.

Acceptance: A release dashboard derives status from code/test evidence and cannot count designed-only tasks as delivered capability.

F-047 - SQLite and web-process topology limit safe scale and failover

Severity: high | Status: partially_mitigated | Category: infrastructure | Confidence: high

Finding: SQLite now has immediate-transaction serialization, persisted durable schemas, a repository-owned adapter, outbox leases, and migration checks. The web process still launches the production runner and there is no tested worker fleet or failover topology.

Impact: Multi-process deployment, failover, concurrent writers, and horizontal scaling can corrupt assumptions or lose work.

Recommendation: Define supported single-node limits, separate durable worker execution, and introduce a tested persistence profile before scaling out.

Acceptance: Run load and failover tests at documented limits; unsupported topologies must fail configuration validation.

F-048 - No tested Content Security Policy

Severity: high | Status: partially_mitigated | Category: browser-security | Confidence: high

Finding: A CSP is configured and scanned, but it retains unsafe-inline compatibility directives and has not passed browser-level nonce, third-party, or violation-report testing.

Impact: Cross-site scripting impact is not meaningfully contained at the browser policy layer.

Recommendation: Design and roll out report-only then enforced CSP with route-level automated checks.

Acceptance: All production pages load under enforced CSP with no unauthorized script, style, frame, connect, image, or font source.

F-049 - Tool arguments are not uniformly governed by explicit versioned schemas

Severity: high | Status: fixed_in_v11 | Category: capability-security | Confidence: high

Finding: Tools declare versioned schemas and capabilities; arguments are validated, allowlists enforced, and execution is bounded by timeout and output size.

Impact: Malformed, oversized, ambiguous, or injected arguments can reach tool implementations inconsistently.

Recommendation: Add OS-level isolation for high-risk tools and maintain mutation tests for schema bypass.

Acceptance: Fuzz every tool with invalid types, extra fields, oversized values, Unicode edge cases, and schema-version mismatch.

F-050 - Context and output budgets are incomplete

Severity: high | Status: partially_mitigated | Category: context-engineering | Confidence: high

Finding: Run requests now bound context and output tokens; context assembly deterministically preserves mandatory messages and recent complete segments under budget. Adaptive stopping, cache isolation, and omission-quality benchmarks remain.

Impact: Long histories or retrieved content can crowd out policy/current facts, increase cost, and degrade correctness.

Recommendation: Implement mandatory-context reservation, measured selection, output ceilings, and bounded planner/critic/verifier stopping.

Acceptance: Run adversarial long-context cases and prove mandatory policy/current code facts survive while cost and latency remain within budget.

F-051 - Stale workers could commit after lease takeover when identity was reused

Severity: critical | Status: fixed_in_v12 | Category: recovery failure | Confidence: high

Finding: Durable mutations previously checked worker identity and lease time but did not bind commits to a monotonically increasing fencing token. A restarted worker using the same identity could race a newer lease holder.

Impact: Split-brain workers could overwrite checkpoints or complete a job after losing authority, invalidating exactly-once and recovery claims.

Recommendation: Require a fencing token on every lease-bound mutation and reject stale tokens in memory and SQLite adapters.

Acceptance: Acquire a lease twice with the same worker identity after expiry; token 1 must be rejected and token 2 must commit.

F-052 - Approval resolution lacked a cross-process compare-and-set revision

Severity: high | Status: fixed_in_v12 | Category: agent-control failure | Confidence: high

Finding: The active approval row had a status but no revision. Competing processes could both observe pending before one committed a terminal decision.

Impact: A stale operator action or concurrent process could overwrite or contradict the authoritative human decision.

Recommendation: Persist an approval revision and update terminal status only when id, prior status, and revision all match. Return a conflict to stale clients.

Acceptance: Two resolutions using the same expected revision must yield one successful transition and one approval_revision_conflict.

F-053 - Verification decisions were not immutably bound to tested source and release artifacts

Severity: high | Status: fixed_in_v12 | Category: verification failure | Confidence: high

Finding: Run evidence and human review existed, but there was no immutable attestation binding requirement revision, source tree, test output, artifact, builder, verifier, and release candidate.

Impact: A verification label could outlive or refer to different code and test evidence, creating false release confidence.

Recommendation: Create hash-bound verification attestations, reject builder/verifier identity collisions, and expose absent verification in the interface.

Acceptance: Changing any bound field must invalidate the evidence hash; self-verification must be rejected.

F-054 - Runtime calm could be mistaken for release or pilot readiness

Severity: high | Status: fixed_in_v12 | Category: design deception | Confidence: high

Finding: Operational metrics showed local state but did not explicitly gate build, native tests, browser E2E, accessibility, restart recovery, tenant isolation, or extracted-package evidence.

Impact: An operator could interpret zero failures in an empty or lightly used system as evidence that the release was pilot-ready.

Recommendation: Add a conservative evidence gate that treats unknown release evidence as blocking and separates runtime health from release classification.

Acceptance: Healthy empty metrics with unknown release facts must remain DEVELOPMENT ONLY; controlled pilot requires every hard fact.

F-055 - Model routing did not distinguish verification quality or unhealthy candidates

Severity: high | Status: fixed_in_v12 | Category: agent-control failure | Confidence: high

Finding: The measured router scored planning and coding capabilities but lacked an explicit verifier-quality signal and health state.

Impact: Verification tasks could select a strong builder but weak reviewer, or choose an unavailable model if other metrics were attractive.

Recommendation: Record verification quality and health, apply task-class weighting, and reject unavailable candidates as a hard constraint.

Acceptance: A verification task must select the eligible high-verification model and reject an unavailable higher-scoring model.

F-056 - Active approval waits were process-local and could not resume after restart

Severity: critical | Status: partially_mitigated | Category: recovery failure | Confidence: high

Finding: The approval row survived, but the active model/tool continuation originally lived in process memory. v13 adds deterministic continuation keys, durable pause/requeue, revision compare-and-set, expiry, and checkpoint metadata for the bounded pilot path.

Impact: A restart during a risky action could leave the run permanently waiting or tempt an operator to repeat a side effect.

Recommendation: Execute native restart integration in the isolated lane and prove the exact approved step resumes once after process replacement.

Acceptance: Persist a pending approval, terminate the process, restart, resolve the expected revision, and prove one side effect and one terminal durable state.

F-057 - Pilot resources lacked a complete tenant and workspace boundary

Severity: critical | Status: partially_mitigated | Category: tenant isolation failure | Confidence: high

Finding: v13 persists tenant, workspace, owner, and visibility across pilot resources and centralizes personal-scope resolution, but full multi-process and browser authorization testing is pending.

Impact: Resource identifiers could cross user or workspace boundaries even when individual routes appeared owner-filtered.

Recommendation: Run native cross-tenant API, search, artifact, approval, verification, export, backup, and restore tests, including mutations that remove predicates.

Acceptance: Every cross-tenant read and write must fail, and removing one tenant predicate must make the suite fail.

F-058 - Pilot readiness could be implied by static or missing evidence

Severity: high | Status: fixed_in_v13 | Category: misleading success | Confidence: high

Finding: v13 derives pilot readiness from run, durable job, receipt, approval, model, memory, capability, artifact, reconciliation, verification, and release evidence. Unknown evidence is blocking.

Impact: Operators could interpret an incomplete checklist or completed run as proof that the release was safe for pilot use.

Recommendation: Keep fail-closed evidence semantics and regression tests for every unknown gate.

Acceptance: Removing any mandatory evidence item must change the run to blocked and identify the missing evidence.

F-059 - Database initialization during module import broke production build discovery

Severity: high | Status: fixed_in_v13 | Category: build reproducibility | Confidence: high

Finding: The database was opened eagerly when API modules were imported during Next.js page-data collection. v13 opens SQLite lazily on first real database operation and forces authenticated application rendering to remain dynamic.

Impact: A clean source build required a native runtime binding even when no database query was executed, preventing reproducible packaging and hiding build/runtime boundaries.

Recommendation: Retain lazy initialization and verify the complete build in both source-safe and native CI lanes.

Acceptance: Import the database module without a native binding and complete `next build` without opening SQLite.

F-060 - Native persistence validation is unavailable on the protected host

Severity: high | Status: partially_mitigated | Category: release verification | Confidence: high

Finding: v14 runs the complete persistence suite through Node 22 built-in SQLite without downloading or building a new binary. The better-sqlite3 native lane remains available in pinned CI but is not locally proven.

Impact: SQLite transactions, multi-process races, migrations, durable approval restart, and production runtime behavior are not locally proven.

Recommendation: Run the pinned isolated validation workflow and attach dependency provenance, native results, migrations, build, and resource metrics.

Acceptance: The isolated lane must install from lockfile, run all native suites, and publish machine-readable evidence with exact package and binary provenance.

F-061 - Browser, accessibility, and visual regression gates are not executed locally

Severity: high | Status: environment_blocked | Category: accessibility blocker | Confidence: high

Finding: Chromium is installed, but organization-managed policy sets URLBlocklist to ["*"], blocking localhost before application navigation. The managed policy was not modified or bypassed.

Impact: Keyboard, focus, responsive, accessibility, restart, reconciliation, and operator-truth behavior are not browser-verified.

Recommendation: Execute Chromium, Firefox, mobile, accessibility, and visual regression in the pinned disposable CI lane.

Acceptance: All pilot browser scenarios must pass with screenshots, traces, accessibility results, and responsive evidence.

F-062 - Final verification is not yet independently bound to the released ZIP hash

Severity: critical | Status: open | Category: verification failure | Confidence: high

Finding: v13 includes a hash-bound verifier that rejects incomplete evidence, but no operationally separate verifier has accepted a final archive after native and browser gates.

Impact: The builder could package source that differs from tested evidence or overstate readiness.

Recommendation: Freeze the release, execute all isolated gates, bind evidence to the archive hash, and run a distinct verifier invocation that attempts rejection.

Acceptance: A distinct verifier identity must accept the exact final ZIP SHA-256 with all required evidence hashes and no hidden critical limitation.

F-063 - Live remote model conversations remain outside restart-safe pilot execution

Severity: critical | Status: accepted_risk | Category: agent-control failure | Confidence: high

Finding: The bounded pilot supports simulation and local artifact generation. Remote provider dialogue state is not serialized as durable model intents and immutable response references.

Impact: A restart during a live remote model interaction can require re-execution, consume additional cost, or produce a non-equivalent response.

Recommendation: Deny live-provider pilot execution until model request intents, response references, replay policy, cost accounting, and privacy scope are durable.

Acceptance: Terminate before and after a remote response and prove deterministic continuation or explicit reconciliation without silent re-request.

F-064 - Runtime migration discovery applied only the first declared schema change

Severity: critical | Status: fixed_in_v14 | Category: data-loss risk | Confidence: high

Finding: The legacy migration journal listed only 0000 even though later SQL migrations existed. Runtime startup therefore could create an outdated schema while source validation merely counted files.

Impact: Production startup could omit durable, memory, tenancy, verification, and approval columns, creating runtime failures and misleading release evidence.

Recommendation: Keep ordered SQL files canonical, persist each filename and SHA-256, and reject migration drift.

Acceptance: Apply all migrations to a clean database, rerun idempotently, and fail after modifying a historical migration.

F-065 - Static generation inherited an unbounded host CPU count

Severity: high | Status: fixed_in_v14 | Category: performance collapse | Confidence: high

Finding: Next.js inferred a very large CPU count in the container and spawned excessive static-generation workers.

Impact: Builds could stall, exhaust memory, or interfere with other workloads on high-core-count hosts.

Recommendation: Keep explicit bounded build concurrency and record build duration and route metrics.

Acceptance: Complete the production build with two workers and a successful exit.

F-066 - Demo seed referenced tenant and workspace identifiers without creating the scope rows

Severity: high | Status: fixed_in_v14 | Category: tenant isolation failure | Confidence: high

Finding: The seeded runs carried personal tenant and workspace identifiers while the tenants, workspaces, and memberships tables remained empty.

Impact: Demo and E2E state could appear scoped while lacking the membership records used by backend authorization.

Recommendation: Create the personal pilot scope before seeding scoped agents or runs.

Acceptance: Seed a clean database and verify tenant, workspace, membership, run, approval, and artifact scope survive backup and restore.

F-067 - The local browser executable is governed by a deny-all URL policy

Severity: high | Status: environment_blocked | Category: accessibility blocker | Confidence: high

Finding: The installed Chromium returns ERR_BLOCKED_BY_ADMINISTRATOR for localhost because its managed URLBlocklist contains a wildcard deny rule.

Impact: Browser E2E, keyboard, responsive, offline, accessibility, and visual-regression claims cannot be made from this host.

Recommendation: Execute the pinned browser lane in a disposable CI worker and retain the local block as a release blocker.

Acceptance: The same frozen candidate passes Chromium browser, accessibility, offline, and responsive tests in the disposable lane.

F-068 - Restore interruption after target displacement lacked a rollback proof

Severity: high | Status: fixed_in_v14 | Category: recovery failure | Confidence: high

Finding: The restore implementation had rollback code, but no deterministic kill-point proved that the original target is restored after displacement and before commit.

Impact: An interrupted restore could have been claimed atomic without evidence at the most dangerous boundary.

Recommendation: Retain explicit fault injection and regression coverage around target displacement.

Acceptance: Inject failure immediately after displacement and verify the original target bytes remain available.

F-069 - Full-process outbound network behavior is not independently audited

Severity: high | Status: partially_mitigated | Category: security-egress | Confidence: high

Finding: The sovereign network guard proves declared adapter policy, but no packet- or syscall-level audit has observed the complete application during startup, build, workflow execution, and shutdown with outbound traffic denied.

Impact: An undeclared dependency or library call could escape the application-level guard and invalidate air-gap claims.

Recommendation: Extend process attribution to Windows and an unrestricted browser/model lane; increase sampling or add firewall event evidence.

Acceptance: The full pilot workflow records zero unexpected remote connection across application, browser, model, and child processes.

F-070 - No real local generative model artifact has been benchmarked

Severity: critical | Status: open | Category: model-routing | Confidence: high

Finding: The deterministic local runtime proves contracts and zero-key orchestration, while the medium local model is only a hardware profile and was not downloaded or executed.

Impact: Model sovereignty, task quality, tool reliability, memory behavior, latency, and hardware feasibility remain unproven for a useful generative workload.

Recommendation: Benchmark at least one license-reviewed local model artifact in a disposable environment and bind its hash, runtime, quality, memory, latency, and energy evidence to the registry.

Acceptance: A real local model completes the sovereign golden workflow and adversarial structured-output tasks without commercial keys.

F-071 - Energy-aware scheduling uses estimates rather than measured hardware data

Severity: high | Status: open | Category: economics | Confidence: high

Finding: The placement and energy policy contracts are implemented, but power, thermal, load, and task-energy values are synthetic estimates.

Impact: Energy-saving, thermal-protection, and local-versus-remote break-even decisions may be materially wrong on target hardware.

Recommendation: Collect repeated wall-power or trusted telemetry measurements for idle, model load, inference, retrieval, backup, and restore.

Acceptance: Measured profiles include confidence intervals and alter routing only within validated bounds.

F-072 - Clean offline installation still depends on an unbuilt dependency bundle

Severity: high | Status: partially_mitigated | Category: supply-chain | Confidence: high

Finding: The source release and signed update are self-contained, but a new machine still requires JavaScript packages, system prerequisites, browser artifacts, and any real model artifact from external sources.

Impact: Loss of public registries or model hubs prevents clean installation and disaster recovery onto replacement hardware.

Recommendation: Package or separately verify a compatible Node runtime and prove installation on the target clean machine.

Acceptance: A clean target installs source, runtime, dependencies, browser and model artifacts with public registries denied.

F-073 - Signed air-gap bundles were replayable and ignored local key revocation

Severity: high | Status: fixed_in_v15 | Category: capability-security | Confidence: high

Finding: Signature validation alone accepted a copied task or result repeatedly and could not reject a compromised node key.

Impact: An attacker or operator error could repeat bounded work, duplicate local writes, or accept evidence from a revoked offline node.

Recommendation: Retain purpose-scoped trust checks and a durable replay ledger at the acceptance boundary.

Acceptance: A new process instance rejects a consumed bundle, and a revoked key is rejected before payload acceptance.

F-074 - Offline update migration execution is declared but not automatically rehearsed

Severity: high | Status: fixed_in_v16 | Category: supply-chain | Confidence: high

Finding: The signed update format lists migration files and validation commands, and file apply/rollback is proven, but the update engine does not execute migrations or capture a reversible database rehearsal.

Impact: A source update may apply successfully while its schema change fails or cannot be rolled back.

Recommendation: Keep migration rehearsal as a release gate for every signed update.

Acceptance: A real previous-version database migrates, validates, rolls back, and preserves prior data.

F-075 - Root and signing keys lack protected hardware custody and rotation proof

Severity: medium | Status: partially_mitigated | Category: cryptography | Confidence: high

Finding: Context-separated keys, signing identities, validity, purpose and revocation are implemented, but root keys and private signing keys remain process memory or PEM material in the proof harness.

Impact: Host compromise could expose all software-protected sovereign identities and backup keys.

Recommendation: Implement optional OS keychain or TPM-backed adapters, rotation ceremonies, recovery-key separation, and secret-access audit.

Acceptance: Rotate installation, tenant, backup, and signing keys without losing authorized data; revoked versions cannot sign or decrypt new material.

F-076 - Monolithic test orchestration retains an open handle after all suites report

Severity: medium | Status: fixed_in_v16 | Category: reliability | Confidence: high

Finding: The complete Vitest run reports every suite as passing but does not terminate within the bounded window; split deterministic runs terminate and prove all tests.

Impact: CI can hang after successful tests, wasting capacity and obscuring real timeouts.

Recommendation: Retain isolated per-file execution as release authority and diagnose the monolithic command separately.

Acceptance: Every discovered test file exits in a bounded child process and the aggregate gate exits zero.

F-077 - Real browser and accessibility evidence is blocked by managed navigation policy

Severity: high | Status: environment_blocked | Category: accessibility | Confidence: high

Finding: Authenticated Chromium tests reach the browser but every localhost navigation is rejected with ERR_BLOCKED_BY_ADMINISTRATOR.

Impact: Keyboard, focus, responsive, offline, failure-state, and screen-reader behavior cannot be promoted from contracts to runtime evidence.

Recommendation: Run the frozen source in a disposable browser environment without the managed deny-all URL policy; do not alter the protected host policy.

Acceptance: Chromium and a second engine complete the sovereign workflow, accessibility scan, keyboard flow, and visual states.

F-078 - No real local generative model executed despite a complete runtime contract

Severity: critical | Status: open | Category: sovereignty | Confidence: high

Finding: The local runtime lifecycle and candidate profile exist, but qualification found no signed model artifact and no loopback runtime endpoint.

Impact: Reasoning quality, structured output, tool behavior, memory use, latency, RAM, and energy remain unproven for sovereign intelligence.

Recommendation: Execute the hash-verified candidate or another licensed local model on the target mini-PC and run the canonical benchmark.

Acceptance: A real local model passes quality, authorization, structured output, tool, memory, recovery, latency, and hardware thresholds.

F-079 - Portable key custody is not equivalent to OS or hardware-backed custody

Severity: high | Status: open | Category: secrets | Confidence: high

Finding: v16 separates and encrypts key purposes, but private material remains exportable after passphrase-based decryption and no TPM or OS keychain adapter was proven.

Impact: Filesystem or passphrase compromise can expose signing and encryption material required for high-value sovereign operation.

Recommendation: Implement and validate a target-platform OS keychain or hardware-backed adapter with recovery and rotation drills.

Acceptance: Non-exportable or OS-protected keys sign, rotate, revoke, recover, and reject cross-purpose use on target hardware.

F-080 - Offline retrieval fallback has no semantic embedding comparison

Severity: medium | Status: partially_mitigated | Category: memory | Confidence: high

Finding: The governed BM25 fallback is local and safe, but no local embedding or reranking model was available for quality comparison.

Impact: Lexical retrieval may miss semantically relevant evidence or overvalue repeated terms.

Recommendation: Benchmark lexical, local embedding, hybrid, reranked, and disabled retrieval on a fixed sovereign task corpus.

Acceptance: A selected strategy improves precision and task correctness without increasing unsafe-action or context-contamination rates.

F-081 - Offline installation still assumes a compatible preinstalled Node runtime

Severity: high | Status: partially_mitigated | Category: supply-chain | Confidence: high

Finding: Locked dependencies install from a verified cache without registry access, but Node and platform-level prerequisites are not included in a signed installation bundle.

Impact: A clean bare machine cannot yet be installed from TITAI media alone.

Recommendation: Create platform-specific signed runtime bundles or a verified installer manifest and prove installation on the target machine.

Acceptance: A clean target with no public network installs the runtime, dependencies, source, migrations and application from signed media.

F-082 - Physical multi-node and long-disconnection conflict behavior remains unproven

Severity: high | Status: partially_mitigated | Category: multi-agent | Confidence: high

Finding: A separate worker process and signing identity passed capability, scope, integrity, and replay checks on one host; two physical nodes and long-disconnection conflict semantics were not exercised.

Impact: Network partitions, clock differences, deletion propagation, and divergent authoritative state may behave differently across machines.

Recommendation: Run the signed lease on the user's mini-PC or a second VM and test revocation, deadlines, stale results and conflicting offline changes.

Acceptance: Two isolated nodes complete and reintegrate work under failure without cross-scope access or silent conflict merge.

F-083 - Energy-aware routing has no target-hardware measurement

Severity: high | Status: open | Category: energy | Confidence: high

Finding: The current environment reports CPU and RAM but exposes no supported energy counter and is not the user's target mini-PC.

Impact: Energy utility values may be inaccurate and must not control model or node selection.

Recommendation: Measure idle, load, model startup, inference, retrieval, backup, restore and thermal behavior on the target hardware.

Acceptance: Hardware-provenance measurements provide bounded confidence and remain advisory until thresholds are validated.

F-084 - The initial isolated test runner contained invalid JavaScript syntax

Severity: medium | Status: fixed_in_v16 | Category: developer-platform | Confidence: high

Finding: A TypeScript non-null assertion was accidentally placed in an .mjs file, preventing the new authoritative test command from starting.

Impact: A release-control improvement could itself have become an unexecuted documentation claim.

Recommendation: Run node syntax validation for every JavaScript release script and retain the executed full-suite evidence.

Acceptance: The corrected runner starts, executes every discovered test in a bounded child process, and exits zero.

15. Honest Limitations and Next Proof

Independently or reproducibly verified in this environment

- Canonical, language, lint, migration, type, release, and Roast source gates.
- Sixty-four isolated test files and 195 tests with bounded process exit.
- Full production build with bounded workers.
- Portable purpose-separated encrypted key custody.
- Governed lexical retrieval without embeddings or network.
- Real v15-to-v16 SQLite migration application and rollback.
- Clean source dependency installation from a preverified npm cache with registry access disabled.
- Linux process-attributed network evidence for the sovereign proof workflow.
- Separate-process signed worker execution with tenant/workspace scope and replay rejection.

Implemented and tested but not a full production proof

- Local runtime lifecycle and loopback adapters.
- Signed isolated-node execution on one physical host.
- Network evidence based on Linux `/proc` sampling plus application instrumentation.
- Offline installation that assumes a compatible preinstalled Node runtime and a cache prepared before disconnection.

Environment blocked

- Real browser E2E and accessibility: managed Chromium returns `ERR_BLOCKED_BY_ADMINISTRATOR` for localhost.
- Real local generative model benchmark: no hash-verified model artifact and no local model endpoint were available; shell acquisition was unavailable.
- OS or hardware-backed key custody: no target keychain, TPM, smart card, or hardware token was available.
- Target mini-PC energy measurement: the current container exposes no supported energy counter and is not the target machine.

Not claimed

- A bare-metal offline installer containing Node and all platform packages.
- Quality or safety of Qwen, llama.cpp, Ollama, or any other local model runtime.
- Two-physical-machine synchronization or automatic conflict merging.
- Windows process-level socket attribution.
- Hardware-backed non-exportable signing keys.
- Controlled pilot readiness.

Release decision

SOVEREIGN DEVELOPMENT MODE plus DEVELOPMENT ONLY. Unknown model, browser, hardware-key, target-energy, and final independent environment evidence remain blocking.

Required v17 operational lane

- Run a signed local model artifact on the target mini-PC and bind benchmark results to routing eligibility.
- Run Chromium plus a second engine in a disposable environment without managed localhost denial; complete keyboard, accessibility and visual-regression evidence.
- Implement and validate a target OS keychain or TPM-backed custody adapter.
- Measure target machine energy, temperatures and thermal throttling under model load.
- Repeat release verification on a separate machine or CI identity against the frozen ZIP hash.

16. Final Classification

SOVEREIGN DEVELOPMENT MODE

The release contains meaningful local-first and sovereign controls, but the real local-model, browser, hardware-custody, target-energy and external-verifier evidence required for a sovereign controlled pilot remains incomplete.

DEVELOPMENT ONLY

The production build and all source/test gates pass, but the selected workflow has not yet completed all operational pilot gates in the required target environments.

Final principle: unknown evidence remains blocking evidence. The release is stronger because it rejects promotion rather than because it produces a green label.